Business Case
CloudPay FinTech LLC

Caso aziendale basato sulla mappatura delle pressioni degli stakeholder

DOCUMENTO DI LABORATORIO	CONTESTO: FINTECH

Finalità del documento

Presentare il business case per l’implementazione di un Sistema di Gestione per la Sicurezza delle Informazioni (ISMS) conforme a ISO/IEC 27001, organizzando le pressioni degli stakeholder, la valutazione di implementazione, gli output attesi e il punteggio di qualità.

Struttura

1. Pressioni che guidano il programma
2. Valutazione dell’implementazione
3. Output attesi
4. Punteggio di qualità

1. Le pressioni che guidano il programma

Pressione critica

- CEO — Perso un contratto da 1 milione di dollari a causa di una domanda sulla certificazione ISO. Richiede la certificazione entro 9 mesi.
- NY DFS — L'obbligo legato alla licenza richiede una governance della sicurezza documentata.
- Cliente enterprise (Bank X) — Il punteggio del questionario di sicurezza impedisce la firma del contratto.

Pressione alta

- CTO — Vuole un ISMS che non rallenti la velocità di sviluppo del team engineering.
- CISO — Ha bisogno di governance, responsabilità assegnate e un framework di evidenze.
- Compliance Officer — Non riesce a produrre evidenze su richiesta e vuole registrazioni difendibili.

Pressione media

- Fornitore SOC — Servizio esternalizzato; è necessaria collaborazione sulle evidenze di monitoraggio.
- Responsabile HR — Gestisce la formazione annuale e desidera un monitoraggio migliore dei completamenti.
- Senior Engineer — È interessato all'igiene nella gestione dei segreti e alla pipeline di sviluppo.

Pressione bassa

- Marketing — Vuole mostrare il logo ISO sul sito web per rafforzare la fiducia.
- Office Manager — Chiede se siano necessari lettori badge nelle sale riunioni.

2. Valutazione dell'implementazione

L'implementazione presenta una chiara spinta dall'alto, proveniente dalla leadership e dai partner esterni.

Responsabile del programma: CISO

Sponsor esecutivo: CEO

I primi 90 giorni saranno dedicati a contesto, ambito e metodologia di valutazione del rischio, non all'implementazione dei controlli dell'Allegato A.

3. Output attesi dell'implementazione

- Dichiarazione dell'ambito dell'ISMS
- Registro del contesto
- Registro delle parti interessate
- Politica per la sicurezza delle informazioni
- Matrice RACI dell'ISMS
- Metodologia di valutazione del rischio
- Registro dei rischi
- Piano di trattamento del rischio
- Dichiarazione di Applicabilità (SoA)
- Tracker di implementazione dei controlli
- Registro delle evidenze
- Piano di audit interno
- Documentazione per il riesame della direzione
- Rapporto di preparazione alla certificazione

4. Punteggio di qualità

100%

Corrispondenza completa con la mappatura esperta delle pressioni: 11 stakeholder su 11 prioritizzati correttamente.

Documento di laboratorio: contenuti e priorità riproducono il caso fornito, riorganizzato in italiano.